Rapporto preliminare di incidente IR-2026-03

SOLANDRA E-COMMERCE S.p.A. Sistemi informativi e sicurezza — via dell'Artigianato 8, 20096 Pioltello (MI) Prot. SI/2026/0447 del 4 agosto 2026 — Classificazione: riservato Redatto alle ore 22:40 del 4 agosto 2026 — Stato: incidente aperto, ripristino in corso Redazione: ing. Nicola Perazzi, Responsabile sistemi informativi e sicurezza, con il supporto del gruppo di risposta di Vermiglio Digital Forensics S.r.l. (dott. Sergio Aliprandi, capo squadra)

1. Oggetto e scopo

Il presente rapporto raccoglie quanto accertato nelle prime quindici ore dalla scoperta dell'incidente di cifratura che ha colpito i sistemi di gestione degli ordini e di magazzino. Ha valore preliminare: i dati provengono dai registri disponibili sui sistemi non compromessi, dalle copie forensi acquisite in giornata e dai primi colloqui con il personale. La relazione tecnica conclusiva è a carico di Vermiglio Digital Forensics ed è attesa entro la fine del mese.

2. Sintesi dell'accaduto

L'attività ostile sui nostri sistemi è iniziata domenica 2 agosto 2026 e si è conclusa con la cifratura di due ambienti nella notte tra il 3 e il 4 agosto. L'incidente è stato scoperto martedì 4 agosto 2026 alle ore 07:20, all'apertura del turno di magazzino, quando i terminali di prelievo hanno restituito errore di connessione e sulla postazione di reparto è comparso un file di testo con una richiesta di pagamento.

Il punto di ingresso è stato la sottrazione delle credenziali e della sessione autenticata di un'utenza aziendale, avvenuta dopo l'apertura di un allegato di posta elettronica da parte di un'addetta del back office ordini in turno domenicale. Non risultano, allo stato, accessi a sistemi diversi da quelli indicati al punto 4.

3. Cronologia degli eventi accertati

Orari in fuso Europa/Roma. Le voci contrassegnate con (r) derivano da registri di sistema, quelle con (t) da testimonianza raccolta in colloquio.

Data e ora	Evento
02/08/2026 10:12 (r)	ricezione sulla casella s.morandi di un messaggio con mittente contraffatto, riferito a una conferma d'ordine di un fornitore abituale, con allegato conferma_ordine_4471.xlsm
02/08/2026 10:26 (r)	apertura dell'allegato e abilitazione delle macro dalla postazione PC-BO-14
02/08/2026 10:29 (r)	esecuzione di un componente per la raccolta di credenziali e di cookie di sessione; nessun avviso prodotto dal presidio antivirus in dotazione
02/08/2026 21:47 (r)	primo accesso remoto al portale interno con le credenziali dell'utenza s.morandi e con riuso della sessione già autenticata, da indirizzo IP attestato su servizio commerciale di rete privata virtuale
03/08/2026 00:14 – 05:40 (r)	attività di ricognizione sulla rete di produzione, enumerazione delle condivisioni, lettura della rubrica interna
03/08/2026 23:05 (r)	acquisizione di privilegi amministrativi sul server applicativo ORD-APP-02 mediante credenziali di servizio reperite in un file di configurazione
04/08/2026 00:20 – 01:55 (r)	trasferimento verso servizio di archiviazione esterno di un volume di dati stimato in 38 GB
04/08/2026 02:10 (r)	avvio della cifratura sui volumi di ORD-APP-02 e WMS-DB-01

Data e ora	Evento
04/08/2026 04:55 (r)	termine della cifratura; interruzione dei servizi di prelievo e di gestione ordini
04/08/2026 07:20 (t)	scoperta dell'incidente all'apertura del turno di magazzino; rilevamento del file RECOVER-YOUR-DATA.txt
04/08/2026 07:24 (r)	apertura della richiesta all'assistenza interna n. HD-2026-8841
04/08/2026 07:50	attivazione della procedura interna PSI-04 e convocazione del gruppo di crisi
04/08/2026 08:15	isolamento dei due ambienti compromessi dalla rete di produzione e blocco degli accessi remoti
04/08/2026 08:40	disabilitazione dell'utenza s.morandi e reimpostazione forzata delle credenziali di 214 utenze
04/08/2026 09:05	incarico al gruppo di risposta di Vermiglio Digital Forensics S.r.l., fornitore riconosciuto ai sensi della condizione particolare CP/02 della polizza, e avvio delle acquisizioni forensi
04/08/2026 10:30	comunicazione all'intermediario assicurativo Vialonga Broker S.r.l. per le vie brevi, con richiesta di assenso sull'incarico al fornitore forense
04/08/2026 11:42	apertura del ticket urgente NB-U-88214 al fornitore di servizi cloud, su decisione del gruppo di crisi
04/08/2026 12:00	attivazione di un ambiente temporaneo presso il fornitore di servizi cloud per il contenimento e per il riavvio parziale dei servizi
04/08/2026 15:20	verifica di leggibilità della copia non in linea del 1 agosto: esito positivo su entrambi i sistemi
04/08/2026 16:10	assenso per le vie brevi del liquidatore, trasmesso dall'intermediario, sull'incarico al fornitore forense; ogni altro costo da concordare preventivamente
04/08/2026 18:00	avvio del ripristino dell'ambiente ordini sull'infrastruttura temporanea
04/08/2026 20:15	colloquio con l'addetta del back office ordini e acquisizione della casella di posta per analisi

4. Sistemi e dati interessati

La cifratura ha riguardato il server applicativo della gestione ordini (ORD-APP-02) e la base dati del sistema di magazzino (WMS-DB-01), con i relativi volumi di lavoro. Sono risultati cifrati gli archivi degli ordini dal 2023 in avanti, le anagrafiche di magazzino, le liste di prelievo e i documenti di trasporto in emissione.

Lo store web e il portale dei canali di terzi non sono stati cifrati, ma sono rimasti indisponibili alla vendita perché privati del servizio di conferma degli ordini e della verifica delle disponibilità di magazzino, che risiedono sui due sistemi colpiti. I sistemi di contabilità, il gestionale del personale e la posta elettronica non hanno subito cifratura.

I dati oggetto del trasferimento verso l'esterno descritto nella cronologia comprendono, secondo la ricostruzione in corso, anagrafiche di clienti con indirizzi di spedizione e recapiti, e storico degli ordini. La quantificazione delle posizioni interessate e la valutazione degli adempimenti verso l'autorità di controllo sono

in corso con il consulente incaricato, Redigo Compliance S.r.l.; il termine di settantadue ore dalla conoscenza scade il 7 agosto alle 07:20 ed è annotato nel piano delle attività.

5. Vettore di ingresso e condotta dell'utenza

Il messaggio del 2 agosto riproduceva l'aspetto della corrispondenza di un fornitore con cui l'ufficio scambia conferme d'ordine più volte alla settimana; il dominio del mittente differiva per un carattere. L'addetta ha dichiarato in colloquio di aver aperto l'allegato ritenendolo la conferma attesa per un ordine di reintegro, di non aver notato anomalie e di non aver ricevuto alcun avviso dalla postazione. Ha inoltre riferito di non aver comunicato le proprie credenziali a terzi e di non aver eseguito altre operazioni sul file.

Dalle verifiche svolte non risultano condotte dirette a eludere i presidi in essere, né operazioni compiute dall'addetta dopo le ore 10:30 del 2 agosto, ora in cui ha terminato il turno; gli accessi successivi con la sua utenza sono quelli descritti nella cronologia e non provengono dalla sua postazione. L'apertura dell'allegato appare avvenuta nel normale svolgimento delle mansioni e senza consapevolezza della natura del file. L'accesso remoto era protetto da autenticazione a più fattori: l'attaccante non ha superato il secondo fattore, ma ha riutilizzato il cookie della sessione già autenticata sottratto insieme alle credenziali.

L'addetta ha partecipato alla formazione periodica sul riconoscimento dei messaggi ingannevoli nella sessione del 18 febbraio 2026 (registro formazione FR-2026-02, esito positivo).

6. Richiesta estorsiva

Il file RECOVER-YOUR-DATA.txt, rinvenuto su sei postazioni e su entrambi i sistemi cifrati, contiene la richiesta di pagamento di **6,2 BTC** verso il portafoglio bc1qk3v7ye4t8s2m9x4pq0rj6ldh5c9nu2wgfx4t7a, con termine di 96 ore dal 4 agosto e minaccia di pubblicazione dei dati trasferiti. Il testo indica un canale di contatto su servizio di messaggistica anonima.

Nessun pagamento è stato effettuato. Nessun contatto è stato aperto con l'autore della richiesta. Il testo integrale della nota e i dati del portafoglio sono allegati alla denuncia di sinistro in corso di predisposizione.

Denuncia all'autorità di polizia giudiziaria: appuntamento fissato per il 5 agosto presso il Centro operativo per la sicurezza cibernetica di Milano.

7. Copie di sicurezza e test di ripristino

Le copie di sicurezza sono eseguite giornalmente su appliance dedicata, con una copia settimanale su supporto non accessibile dalla rete di produzione, conservata presso la sede di Pioltello. Le copie in linea sull'appliance sono risultate parzialmente cifrate; la copia settimanale non in linea del 1 agosto 2026 è risultata integra e leggibile, come da verifica delle ore 15:20 riportata nella cronologia.

L'ultimo test documentato di ripristino completo risale al **4 marzo 2026** (registro test BK-2026, riga 3, sistemi provati ORD-APP-02 e WMS-DB-01, esito positivo, durata rilevata 6 ore e 10 minuti), cinque mesi prima della scoperta dell'incidente. Il registro non riporta ulteriori test successivi a quella data: la verifica programmata per il trimestre successivo non risulta eseguita né annotata. La finestra di indisponibilità necessaria alla prova era stata richiesta con la segnalazione interna SI/2026/0301 del 22 giugno 2026 e non è stata concessa per la campagna promozionale di fine giugno; la prova non è stata poi riprogrammata.

Il ripristino in corso utilizza la copia non in linea del 1 agosto. I tempi effettivi di ripristino, il confronto con i tempi rilevati nel test di marzo e l'eventuale incidenza dell'assenza della prova trimestrale saranno valutati nella relazione conclusiva del fornitore forense.

8. Misure adottate e attività in corso

Sono stati isolati i sistemi colpiti, revocate le sessioni attive di tutte le utenze, reimpostate le credenziali di servizio e bloccate le regole di accesso remoto dai servizi di rete privata virtuale commerciali. È stato attivato un ambiente temporaneo presso il fornitore cloud per riportare in linea la gestione ordini in configurazione ridotta. Sono in corso l'analisi forense delle immagini acquisite, la ricerca di persistenze sui restanti server e la ricostruzione puntuale dei dati trasferiti all'esterno.

9. Distribuzione

Amministratore delegato; Direzione amministrazione, finanza e controllo; Risk manager; Vialonga Broker S.r.l.; archivio riservato SI.

ing. Nicola Perazzi Responsabile sistemi informativi e sicurezza Solandra E-commerce S.p.A.